Ensuring GDPR-compliant data transfers in AWS

D4F Assignment

Use case: AWS compliance issues post-Schrems II

Amazon Web Services (AWS), a global cloud service provider, encountered significant compliance issues following the 2020 Schrems II ruling, which invalidated the EU-US Privacy Shield (*Customer Update: AWS and the EU-US Privacy Shield | Amazon Web Services*, 2020).

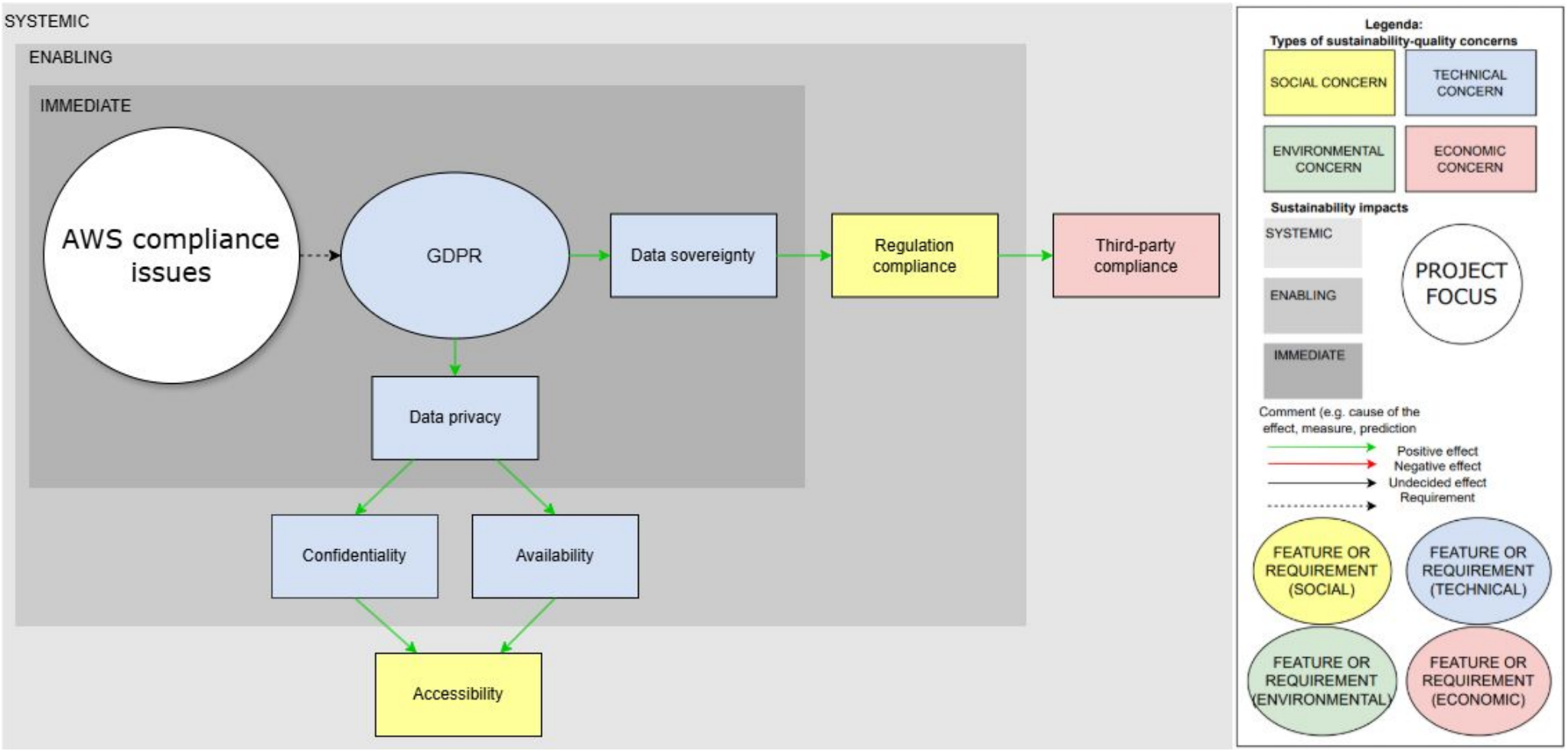
The EU-US Privacy Shield, an agreement allowing companies to transfer personal data from the EU to the US, was ruled inadequate by the Court of Justice of the European Union due to concerns about US surveillance practices (Advisors, 2022).

As a result, AWS, which regularly processes large volumes of EU citizens' data, faced challenges in ensuring that its cross-border data transfers complied with the strict requirements of the EU's General Data Protection Regulation (GDPR).

The ruling left AWS unable to rely on the EU-US Privacy Shield, forcing the company to confront legal and operational obstacles in its data management practices.

Customer update: AWS and the EU-US Privacy Shield | Amazon Web Services. (2020, July 27). Amazon Web Services. https://aws.amazon.com/blogs/security/customer-update-aws-and-the-eu-us-privacy-shield/
Advisors, S. C. (2022, August 28). *Schrems II a summary – all you need to know*. GDPR Summary. https://www.gdprsummary.com/schrems-ii/

Definition of Fairness: Decision Map



Definition of Fairness: Decision Map (cont.)

GDPR	The General Data Protection Regulation (GDPR) is a legal framework that sets guidelines for the collection and processing of personal information from individuals who live in and outside of the European Union (EU).
DATA SOVEREIGNTY	AWS must ensure that data storage and processing comply with EU regulations.
AVAILABILITY	AWS must ensure its services remain operational while adapting to new regulations.
CONFIDENTIALITY	AWS needs to strengthen data access controls to protect personal data.
ACCESSIBILITY	AWS must ensure service availability across regions while complying with legal requirements.
DATA PRIVACY	AWS must enhance data protection measures to comply with GDPR after the EU-US Privacy Shield's invalidation.
REGULATION COMPLIANCE	AWS needs to demonstrate adherence to GDPR and other relevant regulations with proper certifications.
THIRD-PARTY COMPLIANCE	AWS must ensure other companies using their data services also comply to GDPR.

Definition of Fairness: SQ model

QUALITY ATTRIBUTE (QA)	DEFINITION	REFERENCE	TECHNICAL	ENVIRONMENTAL	ECONOMIC	SOCIAL	DEFINITION of METRIC
AVAILABILITY	degree to which a system or component is operational and accessible when required for use	[ISO/IEC 25010:2011]	X				**Uptime percentage** The percentage of time a system is available and operational.
CONFIDENTIALITY	degree to which a system ensures that data are accessible only to those authorized to have access	[ISO/IEC 25010:2011]	X				**Authentication strength** How strong the system's authentication mechanisms are (e.g., multi-factor authentication, password complexity).
ACCESSIBILITY	degree to which a system can be used by people with the widest range of characteristics and capabilities	simplified from [ISO/IEC 25010:2011]				X	**Region-specific content availability** Whether content or services are available to users in different geographic regions.
DATA PRIVACY	the degree to which the collection, storage, or use of personally identifiable information is protected	adapted from [Condori-Fernandez et al. (2020)]	X				**Encryption coverage** The percentage of data that is encrypted both at rest and in transit.
REGULATION COMPLIANCE	the degree to which a system allows to draw conclusions about how well the software adheres to application related regulations in laws	adapted from [Condori-Fernandez et al. (2020)]				X	**Compliance certifications** Measure whether the system has relevant compliance certifications (e.g., ISO 27001, SOC 2) that demonstrate adherence to regulatory standards.
DATA SOVEREIGNTY	the degree to which a system adheres to national or international laws regarding data ownership, control, and jurisdiction, ensuring that data remains under the legal jurisdiction of the country where it originated		X				**Data localization rate** Percentage of data stored and processed within the legal boundaries of a specific jurisdiction.
THIRD-PARTY COMPLIANCE	the degree to which a system ensures that third-party vendors, partners, and contractors follow the same compliance, privacy, and security regulations as the system itself				X		**Contractual compliance** Percentage of third-party contracts that include compliance clauses such as data protection, security measures, and auditing rights.

Definition of Fairness: SQ model (cont.)

AVAILABILITY	AWS must ensure its services remain operational while adapting to new regulations.
CONFIDENTIALITY	AWS needs to strengthen data access controls to protect personal data.
ACCESSIBILITY	AWS must ensure service availability across regions while complying with legal requirements.
DATA PRIVACY	AWS must enhance data protection measures to comply with GDPR after the EU-US Privacy Shield's invalidation.
REGULATION COMPLIANCE	AWS needs to demonstrate adherence to GDPR and other relevant regulations with proper certifications.
DATA SOVEREIGNTY	AWS must ensure that data storage and processing comply with EU regulations.
THIRD-PARTY COMPLIANCE	AWS must ensure other companies using their data services also comply to GDPR.

Fairness perspective

	DESCRIPTION
DESIRED QUALITY	*The ability of the system to treat the data of EU users from US companies with the same level of protection, privacy, and regulatory compliance as that of EU companies, ensuring equal respect for their legal rights and data sovereignty under GDPR*
CONCERNS	*Data equality, regulatory compliance, cross-border data transfers, transparency, data protection rights, accountability and enforcement, equitable treatment, and cultural and legal adaptation*
ARCHITECTURAL TACTIC(S)	*Ensuring GDPR compliance for AWS services by leveraging a European data center and implementing data access control features*
POSSIBLE KPI(S)	*The GDPR compliance assurance KPI measures the effectiveness of data access controls, audit compliance, and incident remediation in ensuring 99% adherence to GDPR guidelines for EU user data processed through AWS services, aligning with the architectural tactic of leveraging a European data center and stringent data access controls to ensure GDPR compliance*
PROBLEMS AND PITFALLS	*Lack of standardization, overreliance on existing frameworks, inadequate data protection mechanisms, complexity of cross-border data compliance, failure to adapt to evolving regulations, and assumption of compliance*

Definition of KPI*

GDPR compliance assurance					
Goal	**Critical Success Factor (CSF)**	**Key Performance Indicator (KPI)**		**Metric(s)**	**Measure(s)**
Ensure that data of EU users processed by AWS services are treated with the same level of protection, privacy, and regulatory compliance as that of EU companies, ensuring equal respect for their legal rights under GDPR	***Achieving regulatory compliance with GDPR, especially with cross-border data transfers, and safeguarding data privacy and sovereignty for EU users, while avoiding legal and operational risks***	***Percentage of GDPR compliance for cross-border data transfers = f(data access control enforcement, audit compliance, incident remediation)***		***Data access control enforcement = f(successful access requests, authorized access, GDPR-compliant authentication)*** ***Audit compliance = f(audit success rate, compliance findings, audit frequency)*** ***Incident remediation = f(response time, breach detection, compliance breach resolution)***	***- Successful access requests*** ***- Authorized access*** ***- GDPR-compliant authentication*** ***- Audit success rate*** ***- Compliance findings*** ***- Audit frequency*** ***- Response time*** ***- Breach detection*** ***- Compliance breach resolution***
		Target	**Action(s)**		
		Achieve 99% compliance with GDPR guidelines for all AWS services involving EU user data processed through the European data center and governed by stringent data access controls	***Regularly update data access control systems, conduct quarterly audits for compliance, train relevant personnel on GDPR, and implement automated alerts for non-compliance incidents, taking corrective actions within 30 days***		

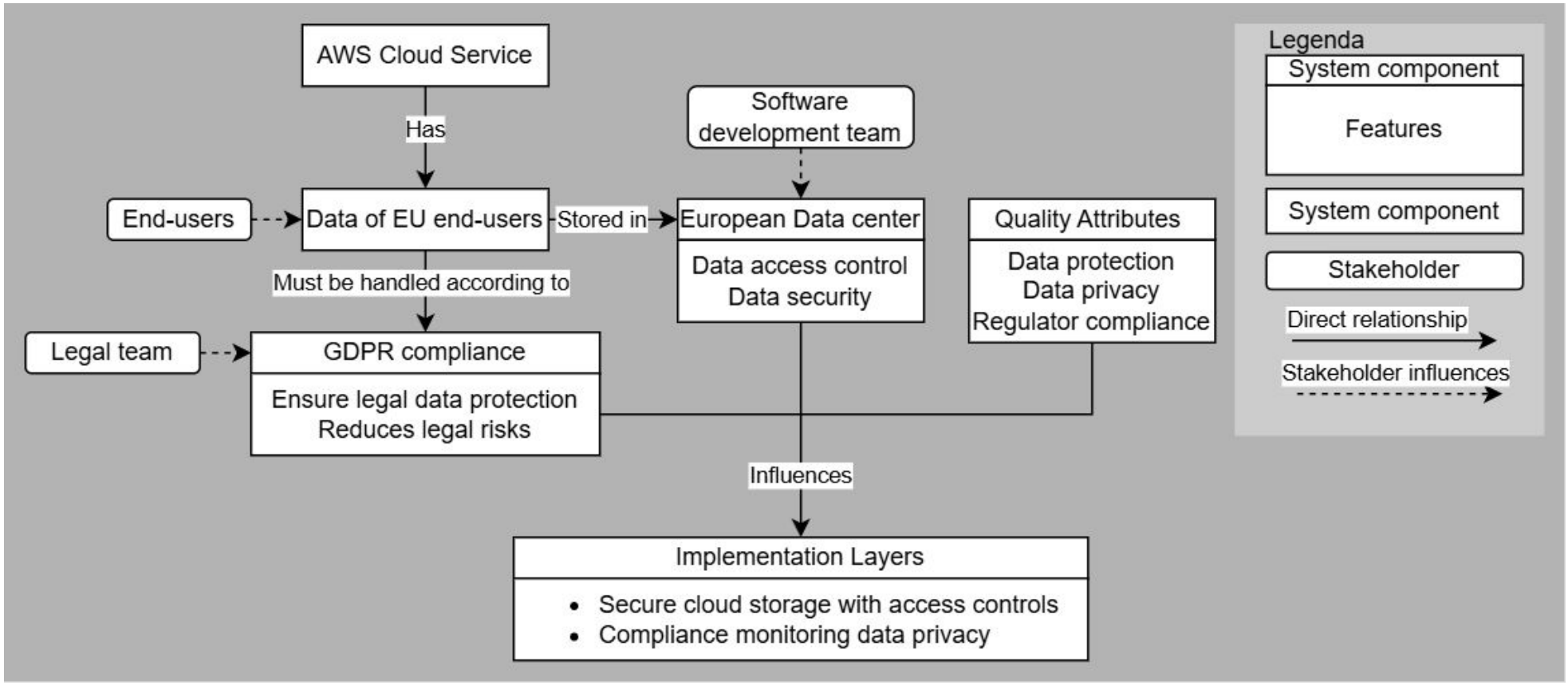
Architectural Tactic(s) for Fairness*


```
<mxfile host="app.diagrams.net" agent="Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0
                                                Safari/537.36" version="26.1.3">
<diagram id="-ry5N-YWXddlaNA1nCuz" name="Awesome Tactic">
  <mxGraphModel dx="1674" dy="738" grid="1" gridSize="10" guides="1" tooltips="1" connect="1" arrows="1" fold="1" page="1" pageScale="1"
  pageWidth="827" pageHeight="1169" math="0" shadow="0">
    <root>
      <mxCell id="0"/>
      <mxCell id="1" parent="0"/>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-2" value="<b>PARTICIPANT:</b><br><font color="#0000de">Software Designer</font>"
      style="shape=umlActor;verticalLabelPosition=bottom;verticalAlign=top;html=1;outlineConnect=0;" parent="1" vertex="1">
        <mxGeometry x="185" y="225" width="30" height="60" as="geometry"/>
      </mxCell>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-3" value="<br><br><br><br><br><br><br><br><b><font color="#000000">CONTEXT:</font></b><br>Legal
      rights to personal data" style="rounded=0;whiteSpace=wrap;html=1;fontColor=#0000DE;fillColor=#E6E6E6;strokeColor=none;" parent="1"
      vertex="1">
        <mxGeometry x="255" y="190" width="270" height="170" as="geometry"/>
      </mxCell>
      <mxCell id="0PLh7_-vrQbvHsDU2Hkp-3"
      style="edgeStyle=orthogonalEdgeStyle;rounded=0;orthogonalLoop=1;jettySize=auto;html=1;exitX=0.25;exitY=0;exitDx=0;exitDy=0;entryX=0.34
      4;entryY=0.988;entryDx=0;entryDy=0;entryPerimeter=0;endArrow=none;endFill=0;dashed=1;" parent="1" source="qT-0_r0VVRt_dCbUm55m-4"
      target="qT-0_r0VVRt_dCbUm55m-9" edge="1">
        <mxGeometry relative="1" as="geometry"/>
      </mxCell>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-4" value="<b><font color="#000000"> ARTIFACT:</font></b><br> European<br> data center"
      style="rounded=0;whiteSpace=wrap;html=1;fontColor=#0000DE;fillColor=#F2F2F2;align=left;" parent="1" vertex="1">
        <mxGeometry x="295" y="200" width="210" height="110" as="geometry"/>
      </mxCell>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-5"
      style="edgeStyle=orthogonalEdgeStyle;rounded=0;orthogonalLoop=1;jettySize=auto;html=1;exitX=0.5;exitY=0.5;exitDx=0;exitDy=0;exitPerime
      ter=0;entryX=0;entryY=0.5;entryDx=0;entryDy=0;fontColor=#0000DE;startArrow=classic;startFill=1;dashed=1;" parent="1"
      source="qT-0_r0VVRt_dCbUm55m-2" target="qT-0_r0VVRt_dCbUm55m-4" edge="1">
        <mxGeometry relative="1" as="geometry"/>
      </mxCell>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-7" value="<b>SOFTWARE<br>FEATURE:</b><br><font color="#0000de">Data access control</font>"
      style="rounded=0;whiteSpace=wrap;html=1;fontColor=#000000;fillColor=#FFFFFF;" parent="1" vertex="1">
        <mxGeometry x="375" y="225" width="120" height="60" as="geometry"/>
      </mxCell>
```

Architectural Tactic(s) for Fairness*


```
      <mxCell id="qT-0_r0VVRt_dCbUm55m-8" value="<b><font color="#000000">TACTIC INTENT:</font></b><br>GDPR compliance for AWS services"
      style="rhombus;whiteSpace=wrap;html=1;fontColor=#0000DE;fillColor=#FFFFFF;" parent="1" vertex="1">
        <mxGeometry x="160" y="80" width="140" height="100" as="geometry"/>
      </mxCell>
      <mxCell id="0PLh7_-vrQbvHsDU2Hkp-4"
      style="edgeStyle=orthogonalEdgeStyle;rounded=0;orthogonalLoop=1;jettySize=auto;html=1;exitX=0;exitY=0.5;exitDx=0;exitDy=0;entryX=1;entryY=0.5;e
      ntryDx=0;entryDy=0;dashed=1;endArrow=none;endFill=0;" parent="1" source="qT-0_r0VVRt_dCbUm55m-9" target="qT-0_r0VVRt_dCbUm55m-8" edge="1">
        <mxGeometry relative="1" as="geometry"/>
      </mxCell>
      <mxCell id="qT-0_r0VVRt_dCbUm55m-9" value="<b>    TARGET QA:</b><br><font color="#0000de">Regulation <br>compliance</font>"
      style="shape=step;perimeter=stepPerimeter;whiteSpace=wrap;html=1;fixedSize=1;fontColor=#000000;fillColor=#FFFFFF;size=40;" parent="1"
      vertex="1">
        <mxGeometry x="285" y="92.5" width="160" height="75" as="geometry"/>
      </mxCell>
      <mxCell id="0PLh7_-vrQbvHsDU2Hkp-1" value="<b>    OTHER RELATED QAs:</b><br><font color="#0000de">Data privacy, Data
      sovereignty</font>" style="shape=step;perimeter=stepPerimeter;whiteSpace=wrap;html=1;fixedSize=1;fontColor=#000000;fillColor=#FFFFFF;size=40;"
      parent="1" vertex="1">
        <mxGeometry x="160" y="30" width="285" height="40" as="geometry"/>
      </mxCell>
      <mxCell id="0PLh7_-vrQbvHsDU2Hkp-2" value="<b>MEASURED</b><br><b>IMPACT:<br></b><font color="#0000de">Reduced legal risk with at least 99%
      compliance with GDPR guidelines</font>" style="shape=note;whiteSpace=wrap;html=1;backgroundOutline=1;darkOpacity=0.05;" parent="1" vertex="1">
        <mxGeometry x="455" y="30" width="90" height="140" as="geometry"/>
      </mxCell>
    </root>
  </mxGraphModel>
 </diagram>
</mxfile>
```

Fairness view: GDPR Compliance View



Fairness view (cont.)

- AWS Cloud Service - The cloud provider managing the data of EU end-users.
- GDPR compliance - An organization that falls within the scope of the GDPR meets the requirements for properly handling personal data.
- Stakeholders:
    - End-users - European users whose data is stored and processed.
    - Legal team - Ensure the compliance with GDPR regulations.
    - Software development team - Implements the security and compliance features.
- Quality attributes:
    - Data protection - Security to prevent unauthorized access.
    - Data privacy - End-users personal data is handled ethically.
    - Regulator compliance - Regulates according to GDPR and legal standards.